ΠΑΝΕΠΙΣΤΗΜΙΟ ΔΥΤΙΚΗΣ ΑΤΤΙΚΗΣ

ΤΜΗΜΑ ΜΗΧΑΝΙΚΩΝ ΠΛΗΡΟΦΟΡΙΚΗΣ
ΚΑΙ ΥΠΟΛΟΓΙΣΤΩΝ

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ
ΕΡΓΑΣΙΑ 4: PKI
3/7/2025

ΠΑΝΤΕΛΗΣ ΚΑΡΑΜΠΕΤΣΟΣ – 20390089

Περιεχόμενα

ΕΙΣΑΓΩΓΗ 3

- **Δραστηριοτητα 1: Δημιουργια Αρχης Πιστοποιησης 3**
- Βημα 1: Δημιουργια Δομης καταλογων 3
- Βημα 2: Τροποποιηση ρυθμισεων openssl.cnf 4
- Βημα 3: Δημιουργια του αυτο-υπογεγραμμενου πιστοποιητικου της ΑΠ 5
- Βημα 4: Έλεγχος του πιστοποιητικου 6

Συμπερασμα 7

- **Δραστηριοτητα 2: Έκδοση Πιστοποιητικου για Πελατη 7**
- Βημα 1: Δημιουργια ζευγους κλειδιων για τον πελατη 7
- Βημα 2: Δημιουργια CSR (Certificate Signing Request) 8
- Βημα 3: Έκδοση Πιστοποιητικου απο την ΑΠ 9

Συμπερασματα 11

- ♦ **Δραστηριοτητα 3: Χρηση του Πιστοποιητικου σε Δοκιμαστικο HTTPS Server 11**
- Βημα 1: Διαμορφωση DNS 12
- Βημα 2: Εκκινηση του OpenSSL 12
- Βημα 3: Προσβαση στο website απο τον browser 13
- Βημα 4: Εισαγωγη του ca.crt στο Firefox 14
- Βημα 5: Δοκιμη και επιβεβαιωση ασφαλους συνδεσης 14

Συμπερασματα 16

- ♦ **Δραστηριοτητα 4: Χρηση του Πιστοποιητικου σε Apache HTTPS Web Server 17**
- Βημα 1: Δημιουργια του ιστοτοπου 17
- Βημα 2: Ρυθμιση του Apache 17
- Βημα 3: Ενεργοποιηση SSL και εκκινηση Apache 18
- Βημα 4: Περιηγηση στον ιστοτοπο 19

Συμπερασματα 19

- ♦ **Δραστηριοτητα 5: Επιθεση τυπου Man-In-The-Middle (MITM) 20**

Σεναριο της επιθεσης 20

- Βημα 1: Τροποποιηση του default-ssl.conf 20
- Βημα 2: DNS spoofing μεσω /etc/hosts 21
- Βημα 3: Αποπειρα προσβασης απο τον browser 21

Συμπερασματα 22

- ♦ **Δραστηριοτητα 6: Επιθεση τυπου Man-In-The-Middle σε Περιπτωση Παραβιασμενης Αρχης Πιστοποιησης (CA) 23**

Σκοπος της Επιθεσης 23

- Βημα 1: Δημιουργια πιστοποιητικου για πλαστο ιστοτοπο 23
- Βημα 2: Ρυθμιση του Apache για το bank.com 24
- Βημα 3: Προσομοιωση DNS Spoofing 25
- Βημα 4: Δοκιμη στο Browser 25

Συμπερασματα 26

Συνοψη 26

ΕΙΣΑΓΩΓΗ

Η κρυπτογραφία δημοσίου κλειδιού αποτελεί θεμέλιο λίθο για την ασφάλεια των επικοινωνιών στο σύγχρονο Διαδίκτυο. Ωστόσο, από μόνη της δεν επαρκεί για να εξασφαλίσει την αυθεντικότητα των εμπλεκόμενων οντοτήτων. Το θεμελιώδες πρόβλημα αφορά την αδυναμία επαλήθευσης του κατόχου ενός δημόσιου κλειδιού: πώς μπορεί κάποιος να είναι βέβαιος ότι ένα δημόσιο κλειδί ανήκει πραγματικά στην οντότητα που ισχυρίζεται ότι το κατέχει;

Οι Υποδομές Δημοσίου Κλειδιού (Public Key Infrastructures PKI) έρχονται να δώσουν λύση σε αυτό το πρόβλημα, παρέχοντας εναν μηχανισμό δημιουργίας, διανομής, διαχείρισης και ανάκλησης ψηφιακών πιστοποιητικών. Βασικό δομικό στοιχείο μιας ΥΔΚ είναι η Αρχή Πιστοποίησης (Certificate Authority CA), η οποία είναι υπεύθυνη για την έκδοση και την υπογραφή των πιστοποιητικών που συνδέουν μια ταυτότητα με ένα δημόσιο κλειδί.

Η παρούσα αναφορά τεκμηριώνει τη διαδικασία δημιουργίας μιας πλήρους Υποδομής Δημοσίου Κλειδιού, βάσει των οδηγιών της Άσκησης 4 του μαθήματος Ασφάλεια στην Τεχνολογία της Πληροφορίας. Οι δραστηριότητες εκτελέστηκαν σε ελεγχόμενο περιβάλλον (SEED Ubuntu 16.04 VM) με χρήση του εργαλείου OpenSSL. Οι οντότητες της ΑΠ και του Πελάτη διαμορφώθηκαν με *προσωπικά στοιχεία*, σύμφωνα με τις απαιτήσεις της εκφώνησης.

Στόχος της εργασίας ήταν η εμπέδωση της λειτουργίας των ΥΔΚ στην πράξη, η κατανόηση της διαδικασίας υπογραφής πιστοποιητικών και η διερεύνηση των επιπτώσεων που μπορεί να έχει η παραβίαση μιας Αρχής Πιστοποίησης, μέσω προσομοίωσης επιθέσεων τύπου Man-In-The-Middle (MITM).

♦ Δραστηριότητα 1: Δημιουργία Αρχής Πιστοποίησης

Η πρώτη δραστηριότητα αφορά την κατασκευή μιας Αρχής Πιστοποίησης (Root Certificate Authority), η οποία θα χρησιμοποιηθεί για την έκδοση και υπογραφή πιστοποιητικών σε επόμενα βήματα. Η ΑΠ αυτή είναι αυτο-υπογεγραμμένη, δηλαδή το αρχικό της πιστοποιητικό υπογράφεται από το ίδιο της το ιδιωτικό κλειδί. Όλα τα βήματα πραγματοποιήθηκαν τοπικά, χρησιμοποιώντας το εργαλείο OpenSSL και λειτουργικό SEED Ubuntu 16.04.

• Βήμα 1: Δημιουργία Δομής καταλόγων

Αρχικά, δημιουργήθηκε ο φάκελος /pki στην επιφάνεια εργασίας και εντός του ο φάκελος seclabCA, ο οποίος αποτελεί τον root φάκελο της Αρχής Πιστοποίησης. Η τελική δομή έχει ως εξής:

~/Desktop/pki

-seclabCA/

--certs/

--crl/

--newcerts/

--private/

-index.txt

-serial

Οι φάκελοι certs, crl, newcerts και private είναι απαραίτητοι για τη λειτουργία του OpenSSL ως CA, καθώς καθορίζουν που θα αποθηκεύονται τα εκδοθέντα πιστοποιητικά, οι λίστες ανάκλησης και το ιδιωτικό κλειδί.

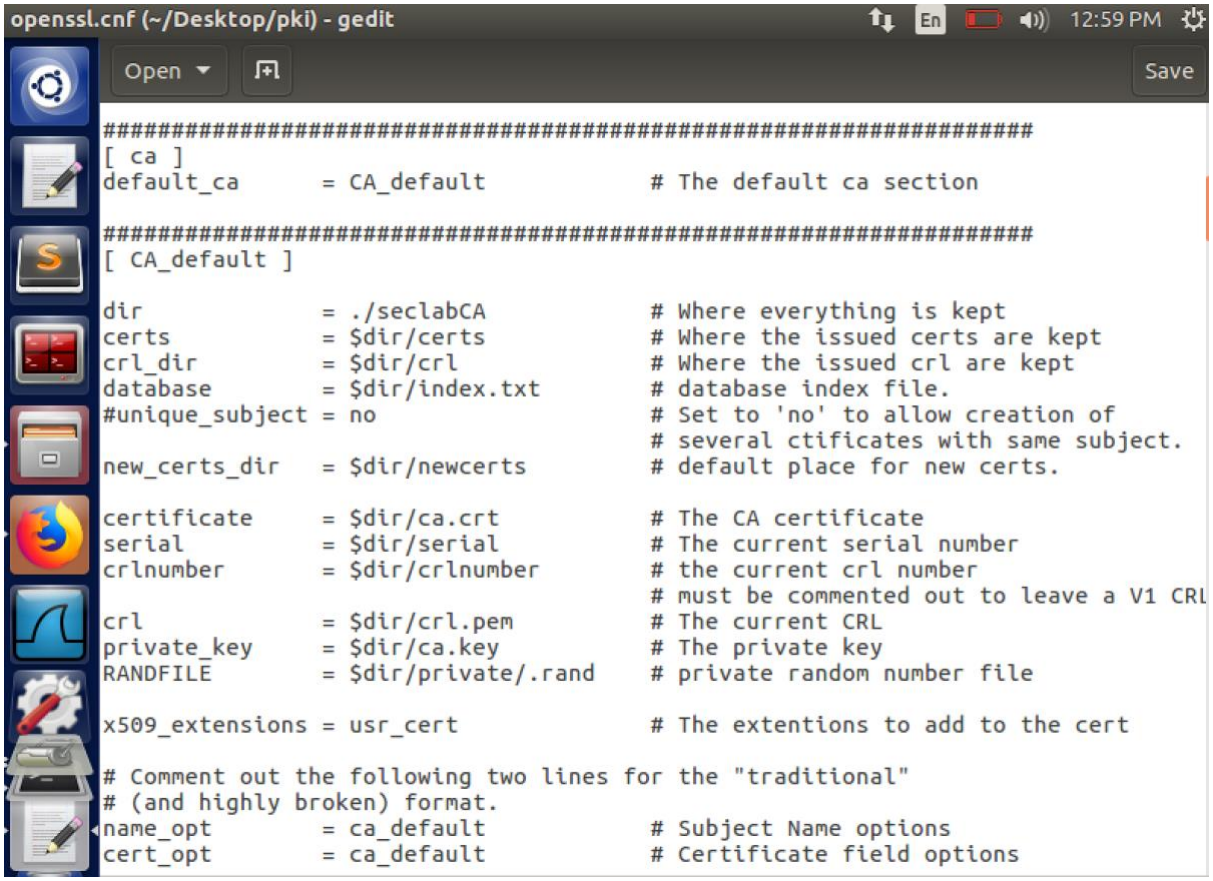
```
[06/02/25]seed@VM:~$ cd ~/Desktop
[06/02/25]seed@VM:~/Desktop$ mkdir -p pki/seclabCA/{cer
ts,crl,newcerts}
[06/02/25]seed@VM:~/Desktop$ touch pki/seclabCA/index.t
xt
[06/02/25]seed@VM:~/Desktop$ echo 0001 > pki/seclabCA/s
erial
[06/02/25]seed@VM:~/Desktop$ cd ~/Desktop/pki/seclabCA
[06/02/25]seed@VM:~/.../seclabCA$ ls -a
.  ..  certs  crl  index.txt  newcerts  serial
```

- Βήμα 2: Τροποποίηση ρυθμίσεων `openssl.cnf`

Το αρχικό αρχείο openssl.cnf αντιγράφηκε από το σύστημα (π.χ. /usr/lib/ssl/openssl.cnf) στον κατάλογο /pki και τροποποιήθηκε κατάλληλα:

- Το πεδίο dir άλλαξε σε ./myCA
- Οι διαδρομές για certificate, private_key, new_certs_dir, serial, index.txt κ.λπ. αντιστοιχίστηκαν στους αντίστοιχους φακέλους
- Η γραμμή policy = policy_match αντικαταστάθηκε από policy = policy_anything ώστε να επιτρέπεται η υπογραφή αιτημάτων χωρίς αυστηρή αντιστοίχιση στα πεδία

Η ενότητα [CA_default] του αρχείου διαμορφώθηκε πλήρως σύμφωνα με τις απαιτήσεις του σεναρίου.



- Βήμα 3: Δημιουργία του αυτο-υπογεγραμμένου πιστοποιητικού της ΑΠ

Η εντολή που χρησιμοποιήθηκε:

```
openssl req -new -x509 -keyout ca.key -out cacert.pem -days 365 -
config openssl.cnf
```

```
[06/03/25]seed@VM:~/.../pki$ openssl req -new -x509 -keyout ca.key -out cacert.pem -days 3
65 -config openssl.cnf
Generating a 2048 bit RSA private key
...........................+++
...........................+++
writing new private key to 'ca.key'
Enter PEM pass phrase:
Verifying - Enter PEM pass phrase:
-----
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:GR
State or Province Name (full name) [Some-State]:ATTICA
Locality Name (eg, city) []:AIGALEO
Organization Name (eg, company) [Internet Widgits Pty Ltd]:UNIWA
Organizational Unit Name (eg, section) []:ICE
Common Name (e.g. server FQDN or YOUR name) []:seclab.uniwa.gr
Email Address []:
[06/03/25]seed@VM:~/.../pki$
```

Κατά την εκτέλεση της εντολής:

- Δημιουργήθηκε ζεύγος κλειδιών 2048-bit RSA (ca.key και cacert.pem)
- Ορίστηκε passphrase για την προστασία του ιδιωτικού κλειδιού

- Συμπληρώθηκαν τα στοιχεία ως εξής:

Πεδίο	**Τιμή**
Country (C)	GR
STATE	ATTICA
Locality	AIGALEO
Organization	UNIWA
Org. Unit	ICE
Common Name (CN)	ice20390089.uniwa.gr

- Βήμα 4: Έλεγχος του πιστοποιητικού

Η εντολή:

```
openssl x509 -in cacert.pem -text -noout
```

```
[06/03/25]seed@VM:~/.../pki$ openssl x509 -in cacert.pem -text -noout
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number:
            f9:e9:15:c7:60:06:0f:26
    Signature Algorithm: sha256WithRSAEncryption
        Issuer: C=GR, ST=ATTICA, L=AIGALEO, O=UNIWA, OU=ICE, CN=seclab.uniwa.gr
        Validity
            Not Before: Jun  3 13:12:12 2025 GMT
            Not After : Jun  3 13:12:12 2026 GMT
        Subject: C=GR, ST=ATTICA, L=AIGALEO, O=UNIWA, OU=ICE, CN=seclab.uniwa.gr
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                Public-Key: (2048 bit)
                Modulus:
                    00:d3:69:10:9d:5b:29:65:07:15:88:6d:62:87:44:
                    6e:e9:25:ee:2d:70:0e:6a:6a:49:42:28:09:1c:c9:
                    16:1c:30:5a:02:e4:d9:43:56:c9:f0:ad:f7:c4:c1:
                    15:ad:bb:4e:2b:8b:e4:4b:fa:9a:1b:0a:0e:49:52:
                    71:cd:e0:f6:fc:dc:57:7a:ca:27:0e:95:40:aa:8f:
                    93:59:7d:a6:32:08:f1:04:59:f3:7a:a8:79:a5:46:
                    1e:f4:a4:e5:2c:cc:fa:58:0b:16:2f:46:4e:78:20:
                    0d:d6:fa:da:06:7f:95:26:7d:59:e1:4f:50:88:7f:
                    bb:c0:f6:56:c6:b6:86:a9:40:3e:0f:3c:0b:fb:58:
                    c2:e9:d7:56:5a:51:9f:90:f8:82:0b:0f:4c:30:62:
                    c6:32:b8:75:38:e1:d3:a9:20:d1:4f:d5:ea:45:74:
                    5c:96:a5:97:2a:c7:55:f1:5d:b5:66:6a:fb:01:82:
                    8a:c7:8a:91:ca:b3:b6:52:7d:f7:38:22:87:25:1c:
                    7a:6e:8d:46:f7:a9:e2:55:1f:19:54:9d:71:d5:80:
                    93:65:fa:1f:24:63:74:c6:04:f7:6f:d3:09:5d:95:
                    96:ec:3d:44:55:0c:30:3b:6f:2e:ef:d8:8b:89:29:
```

Συμπέρασμα

Η Πρωταρχική Αρχή Πιστοποίησης δημιουργήθηκε επιτυχώς με προσωπικά στοιχεία. Το πιστοποιητικό cacert.pem χρησιμοποιήθηκε στις επόμενες δραστηριότητες για την υπογραφή αιτημάτων. Η ΑΠ εισήχθη χειροκίνητα στον Firefox, και ενεργοποιήθηκε με επιλογή εμπιστοσύνης για ταυτοποίηση ιστότοπων.

- ## Δραστηριότητα 2: Έκδοση Πιστοποιητικού για Πελάτη

Σκοπός της δραστηριότητας ήταν η έκδοση και υπογραφή ψηφιακού πιστοποιητικού για έναν πελάτη (website) μέσω της πρωταρχικής Αρχής Πιστοποίησης που δημιουργήθηκε στη Δραστηριότητα 1. Ο πελάτης είναι ένας ιστότοπος με όνομα **pantelis-karabetsos.gr**, όπως απαιτείται από την εκφώνηση.

- ### Βήμα 1: Δημιουργία ζεύγους κλειδιών για τον πελάτη

  Χρησιμοποιήθηκε η ακόλουθη εντολή:

```
openssl genrsa -aes128 -out server.key 1024
```

```
[06/02/25]seed@VM:~/.../pki$ openssl genrsa -aes128 -out server.k
ey 1024
Generating RSA private key, 1024 bit long modulus
..++++++
.........................++++++
e is 65537 (0x10001)
Enter pass phrase for server.key:
Verifying - Enter pass phrase for server.key:
```

Η παραπάνω εντολή:

- Δημιούργησε ζεύγος κλειδιών RSA 1024-bit για τον πελάτη
- Κρυπτογράφησε το ιδιωτικό κλειδί `server.key` με AES-128 και passphrase

```
openssl rsa -in server.key -text
```

επιβεβαιώθηκε ότι το κλειδί είναι κρυπτογραφημένο και περιέχει τα σωστά μαθηματικά στοιχεία (modulus, public exponent, κ.λπ.).

```
[06/03/25]seed@VM:~/.../pki$ openssl rsa -in server.key -text
Enter pass phrase for server.key:
Private-Key: (1024 bit)
modulus:
    00:c4:e3:7c:a7:ec:0c:d0:db:97:12:36:c0:76:49:
    fb:9c:c4:a1:e2:3d:35:50:90:b5:fb:bf:1a:d3:2f:
    d4:20:53:23:2c:3e:f0:85:76:f2:92:f7:bc:3f:07:
    2f:df:96:c9:95:c7:ce:a2:f8:b7:3d:44:ae:0d:c1:
    69:bb:d0:a2:97:7d:a2:a1:79:79:1d:0a:85:04:92:
    b9:cb:92:e4:7d:59:eb:fb:cd:2d:31:c8:b1:b5:45:
    be:02:06:7d:3d:10:01:73:92:4f:e5:5f:65:8e:e3:
    00:cc:b3:72:e7:ca:32:8d:67:fa:5f:fa:98:1d:79:
    6a:bd:21:cf:de:1f:4a:09:05
publicExponent: 65537 (0x10001)
privateExponent:
    73:05:2a:b7:b6:d0:ad:da:fa:e0:6b:17:f8:82:b3:
    f9:1b:6e:2f:0a:ee:f0:87:f9:a8:7e:36:1f:95:db:
    68:9e:e8:f7:5a:35:8c:e2:b6:47:61:6e:99:ab:8b:
    2e:25:9a:d2:63:8d:b5:eb:72:b0:da:44:8c:48:a7:
    8a:4f:12:0c:43:57:95:1f:35:df:46:71:bd:92:3a:
    4f:f7:95:70:d5:8e:47:64:05:b7:87:73:81:a8:1c:
    7f:48:d3:2a:e2:99:20:a0:71:ff:e8:3e:99:b0:5f:
    62:04:99:eb:8f:e2:30:43:c7:2d:03:20:e6:ba:52:
    68:a3:98:61:cc:03:a5:a9
prime1:
    00:ee:0d:c4:ba:89:09:01:e7:77:c7:76:0a:81:68:
    7d:6b:cd:63:ed:a2:5a:1a:4c:68:61:f2:54:5f:dd:
    99:9f:9d:5a:a2:36:eb:e0:ce:f9:fa:1f:80:fc:62:
    e0:7b:fc:64:01:d8:0f:38:43:7f:8e:e6:95:a5:f0:
    b1:27:8d:27:1f
prime2:
    00:d3:bb:44:3c:05:c4:1d:41:b0:c4:86:82:d4:b5:
    38:5b:92:02:74:4b:ec:e5:7c:55:ad:af:f2:5a:49:
    8b:76:76:57:ea:13:54:2c:e6:fe:82:91:b5:d1:1d:
    1b:34:b5:fa:ed:8a:2d:b4:d3:08:7a:44:cc:bc:03:
```

- Βήμα 2: Δημιουργία CSR (Certificate Signing Request)

Εκτελέστηκε η εντολή:

```
openssl req -new -key server.key -out server.csr -config openssl.cnf
```

Κατά την εκτέλεση:

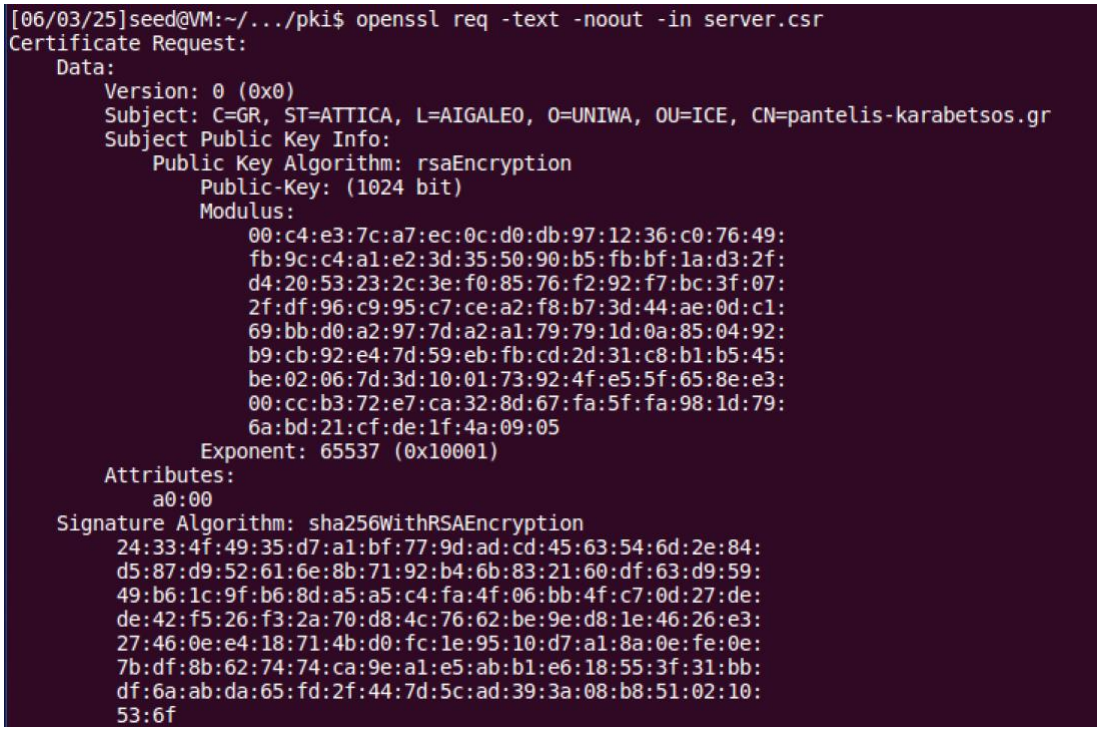
- Ζητήθηκε το passphrase του ιδιωτικού κλειδιού
- Συμπληρώθηκαν τα στοιχεία του πελάτη ως εξής:

Πεδίο	**Τιμή**
Country	GR
State	ATTICA
Locality	AIGALEO
Organization	UNIWA
Org. Unit	ICE
Common Name	pantelis-karabetsos.gr

Τα πεδία "challenge password" και "optional company name" παρέμειναν κενά (Enter)

Ο έλεγχος του CSR έγινε με:

```
openssl req -text -noout -verify -in server.csr
```



- ## Βήμα 3: Έκδοση Πιστοποιητικού από την ΑΠ

Η ΑΠ υπέγραψε το αίτημα CSR και παρήγαγε το τελικό πιστοποιητικό X.509 με:

```
openssl ca -in server.csr -out server.crt -cert cacert.pem
-keyfile private/ca.key -config openssl.cnf
```

```
[06/02/25]seed@VM:~/.../pki$ openssl ca -in server.csr -out server.crt -cert ca.crt -keyfi
le ca.key -config openssl.cnf
Using configuration from openssl.cnf
Enter pass phrase for ca.key:
Check that the request matches the signature
Signature ok
Certificate Details:
        Serial Number: 1 (0x1)
        Validity
            Not Before: Jun  2 19:53:21 2025 GMT
            Not After : Jun  2 19:53:21 2026 GMT
        Subject:
            countryName               = US
            stateOrProvinceName       = NY
            localityName              = NYC
            organizationName          = MyCompany
            organizationalUnitName    = IT
            commonName                = pantelis-karabetsos.gr
            emailAddress              = info@pantelis-karabetsos.com
        X509v3 extensions:
            X509v3 Basic Constraints:
                CA:FALSE
            Netscape Comment:
                OpenSSL Generated Certificate
            X509v3 Subject Key Identifier:
                56:B4:05:55:53:E9:E5:3F:6F:8B:EB:65:00:BE:DF:DD:23:66:9F:33
            X509v3 Authority Key Identifier:
                keyid:D5:00:72:28:50:16:3D:87:45:8F:DC:90:1B:E8:20:12:11:BF:DE:BB

Certificate is to be certified until Jun  2 19:53:21 2026 GMT (365 days)
Sign the certificate? [y/n]:y

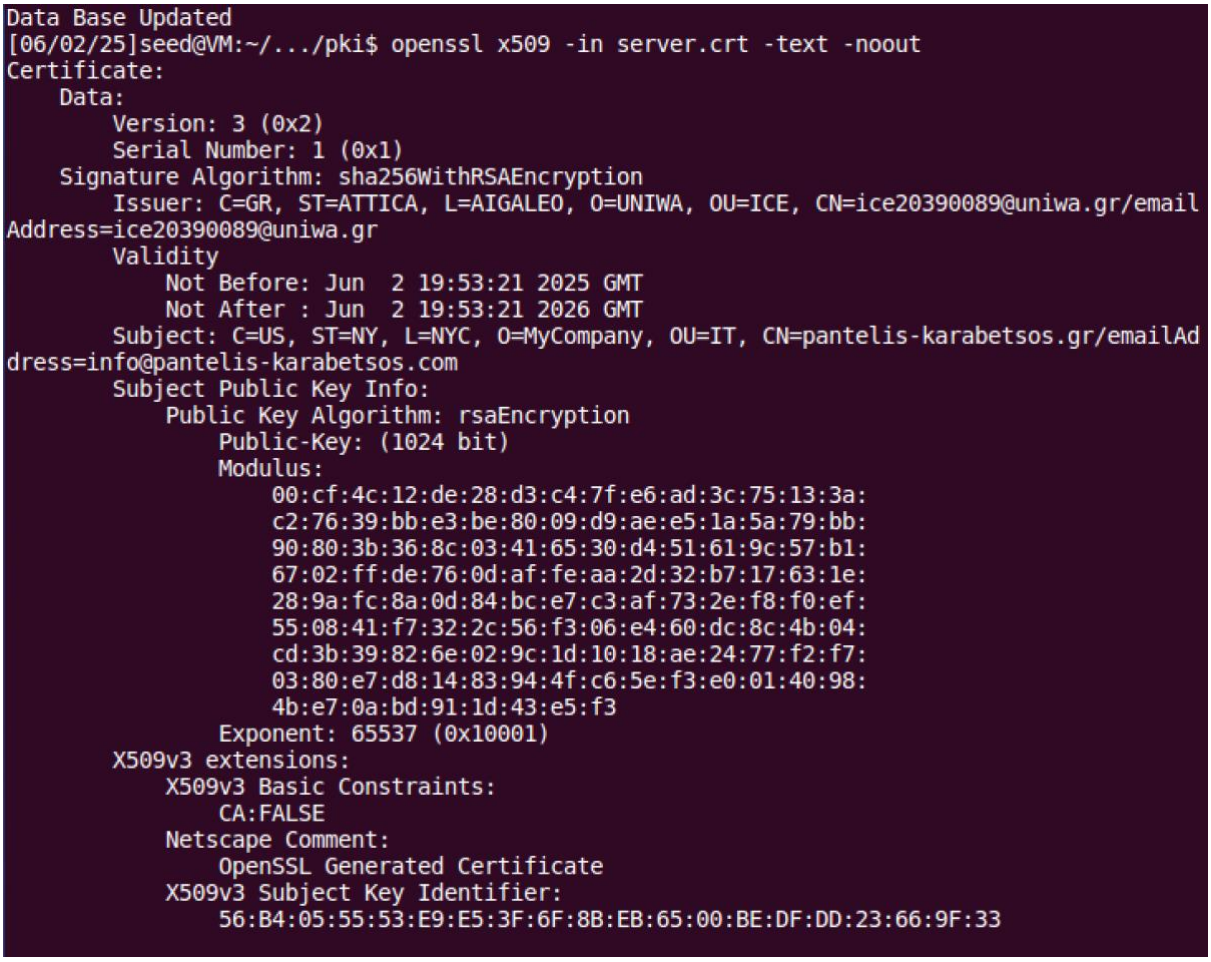

1 out of 1 certificate requests certified, commit? [y/n]y
Write out database with 1 new entries
```

Κατά την εκτέλεση:

- Ζητήθηκε το passphrase του ιδιωτικού κλειδιού της ΑΠ
- Εμφανίστηκαν τα στοιχεία του αιτούντος και ζητήθηκε επιβεβαίωση υπογραφής
- Το πιστοποιητικό καταχωρήθηκε στην εσωτερική βάση δεδομένων της ΑΠ (`index.txt`)
- Δημιουργήθηκε το αρχείο `server.crt`

Ο έλεγχος του τελικού πιστοποιητικού έγινε με

```
openssl x509 -in server.crt -text -noout
```



Συμπεράσματα

Η διαδικασία δημιουργίας, αιτήματος και υπογραφής πιστοποιητικού πραγματοποιήθηκε με επιτυχία. Το τελικό πιστοποιητικό του πελάτη (`server.crt`) μπορεί πλέον να χρησιμοποιηθεί για ασφαλή HTTPS σύνδεση, όπως εξετάζεται και στις επόμενες δραστηριότητες.

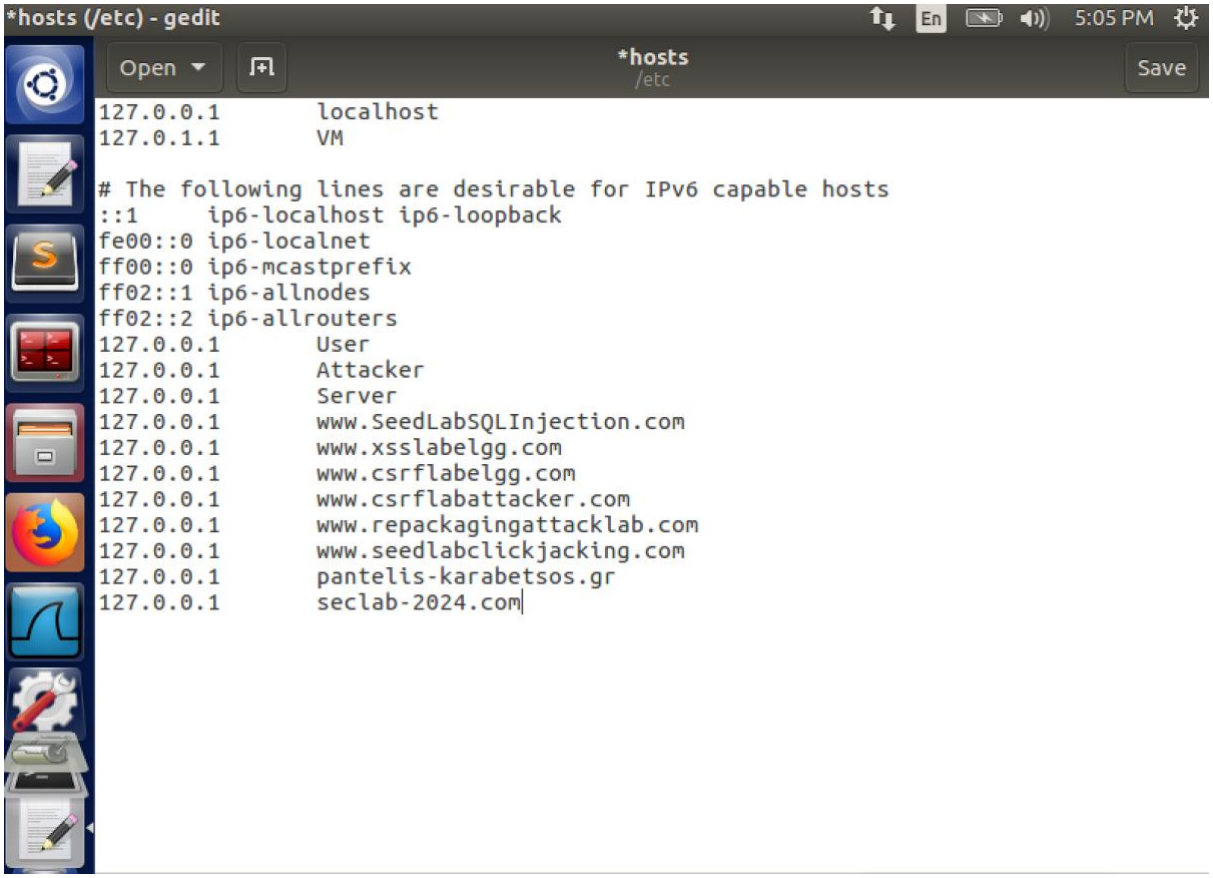
♦ Δραστηριότητα 3: Χρήση του Πιστοποιητικού σε Δοκιμαστικό HTTPS Server

Σκοπός αυτής της δραστηριότητας είναι η πρακτική αξιοποίηση του ψηφιακού πιστοποιητικού του πελάτη για την υλοποίηση ενός ασφαλούς HTTPS server. Για τη δοκιμή χρησιμοποιήθηκε ο ενσωματωμένος HTTPS server που προσφέρει το εργαλείο OpenSSL.

- ## Βήμα 1: Διαμόρφωση DNS

Προστέθηκε εγγραφή στο `/etc/hosts` ώστε το όνομα **pantelis-karabetsos.gr** να αντιστοιχεί στη διεύθυνση `127.0.0.1` (localhost):

127.0.0.1 pantelis-karabetsos.gr



- ## Βήμα 2: Εκκίνηση του OpenSSL

Ο ιδιωτικός φάκελος και το πιστοποιητικό του πελάτη συνδυάστηκαν σε ένα αρχείο .pem:

```
cp server.key server.pem

cat server.crt >> server.pem
```

Στη συνέχεια, εκκινήθηκε ο OpenSSL server με:

```
openssl s_server -cert server.pem -www -accept 4433
```

Ο server άκουγε στην προεπιλεγμένη πόρτα `4433`. Η ένδειξη `ACCEPT` επιβεβαίωσε ότι είναι ενεργός και αναμένει αιτήματα.

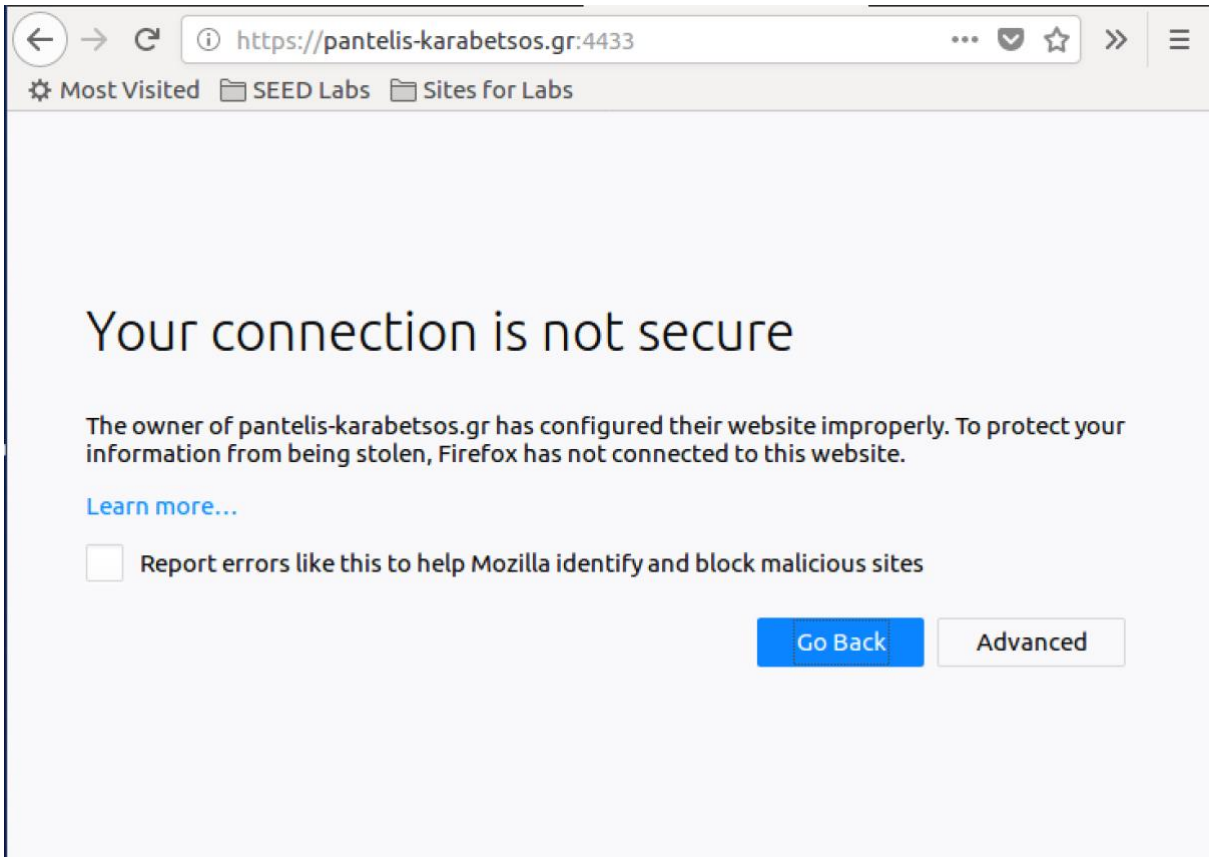
```
[06/02/25]seed@VM:~/.../pki$ openssl s_server -cert server.pem -www -accept 4433
Enter pass phrase for server.pem:
Using default temp DH parameters
ACCEPT
```

- Βήμα 3: Πρόσβαση στο website από τον browser

Ανοίχθηκε ο Firefox και πληκτρολογήθηκε η διεύθυνση:

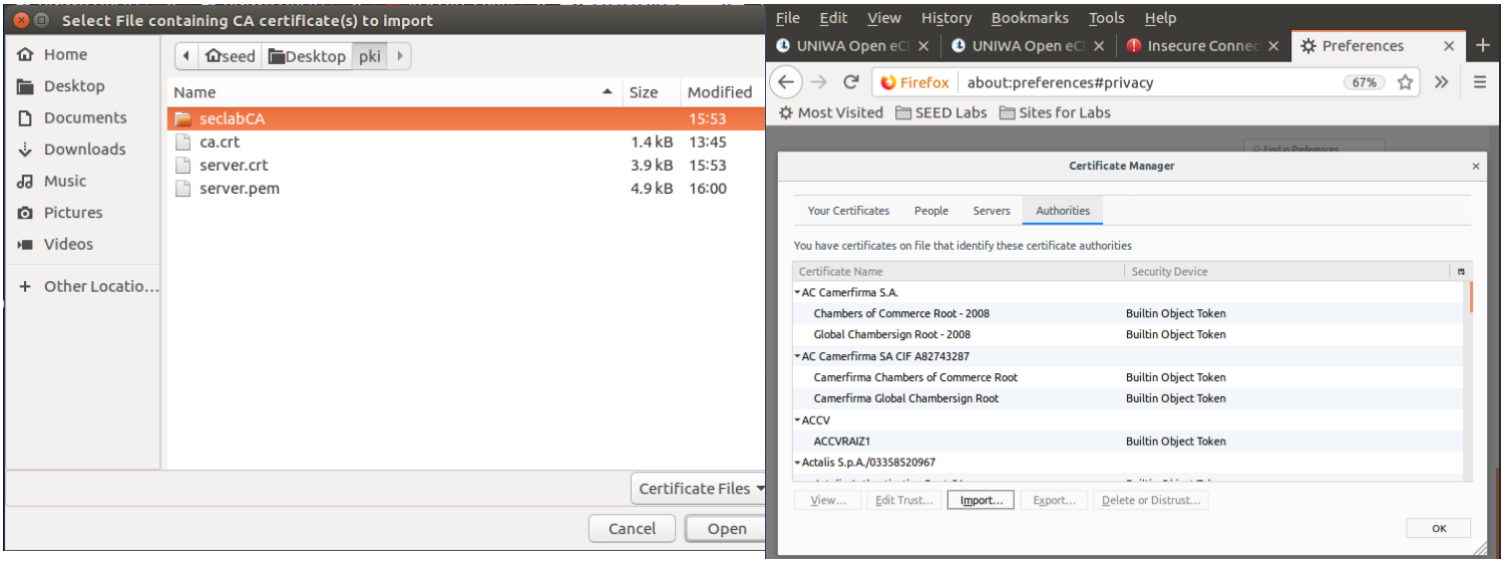
```
https://pantelis-karabetsos.gr:4433
```

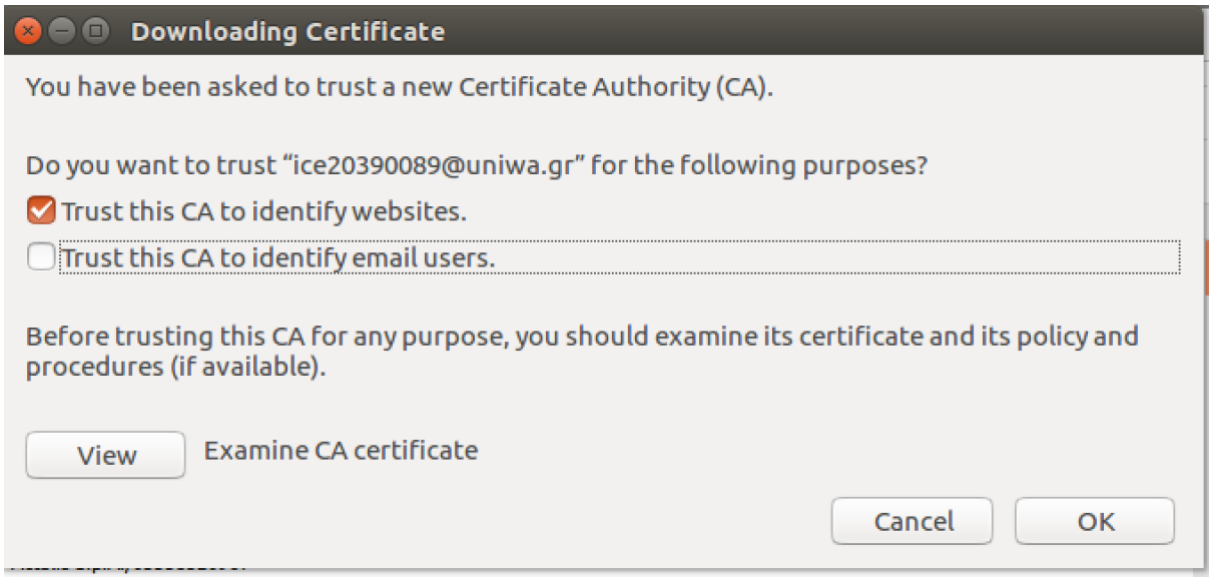
Όπως ήταν αναμενόμενο, εμφανίστηκε προειδοποίηση "Untrusted connection", καθώς το πιστοποιητικό εκδόθηκε από μη αναγνωρισμένη ΑΠ.



- Βήμα 4: Εισαγωγή του ca.crt στο Firefox

1. Από τις ρυθμίσεις του Firefox:
   Edit > Preferences > Privacy > View Certificates > Authorities > Import
2. Επιλέχθηκε το αρχείο ca.cert και ενεργοποιήθηκε η επιλογή:
   "Trust this CA to identify websites"

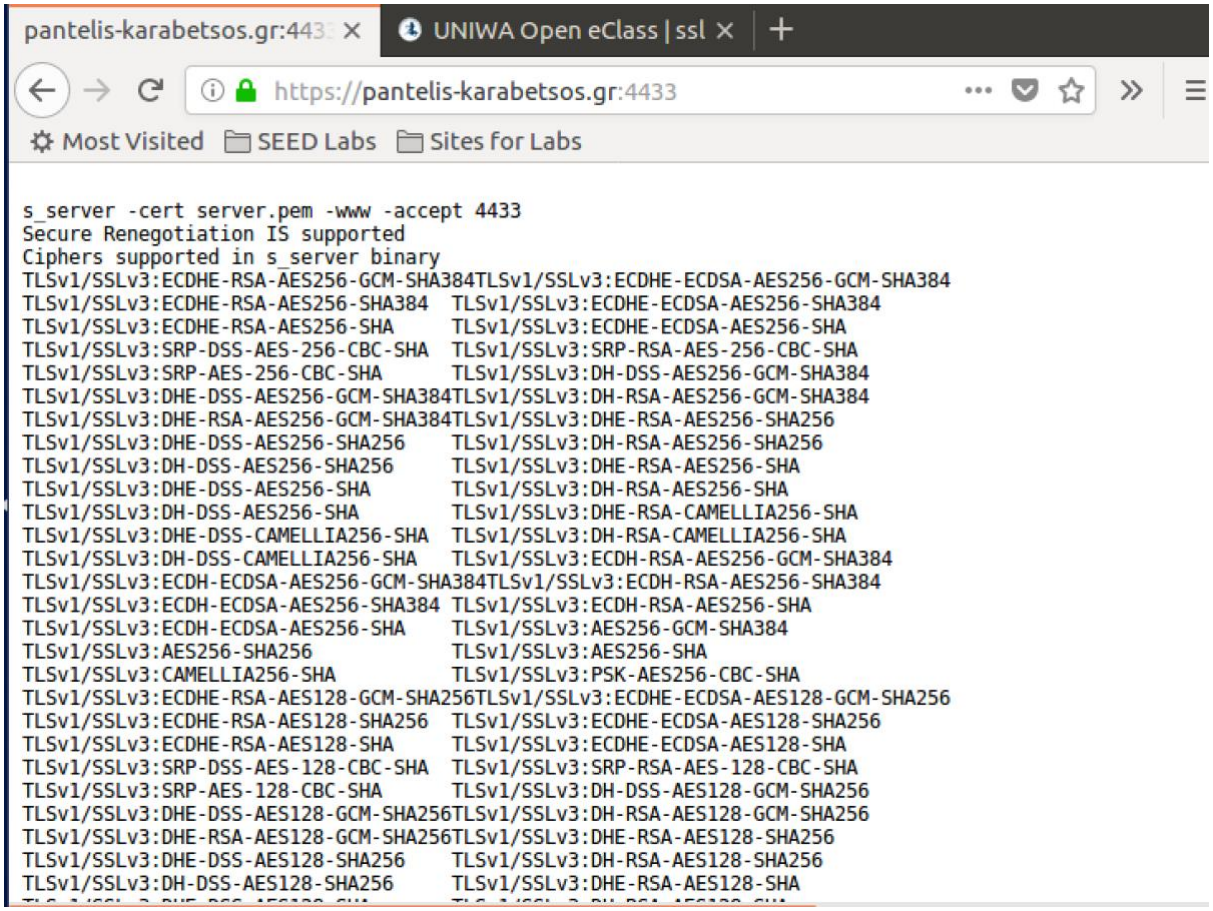




- Βήμα 5: Δοκιμή και επιβεβαίωση ασφαλούς σύνδεσης

Η διεύθυνση `https://pantelis-karabetsos.gr:4433/` επανεισήχθη στον browser και αυτή τη φορά:

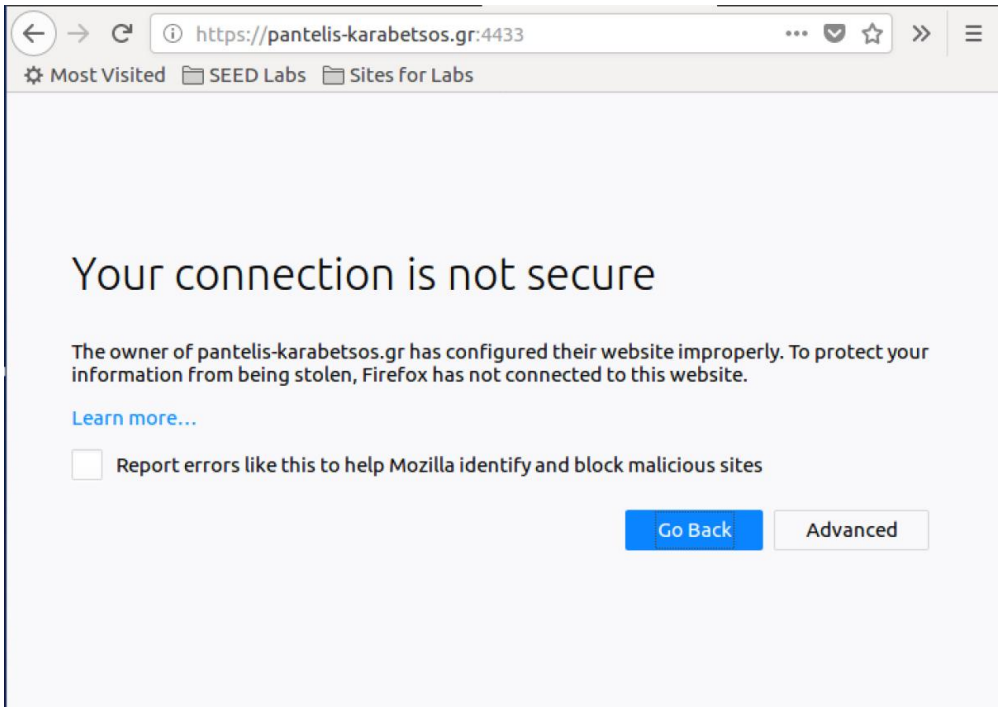
- Η σύνδεση θεωρήθηκε ασφαλής
- Εμφανίστηκε το **πιστοποιητικό του πελάτη**
- Το λουκέτο ασφαλείας εμφανίστηκε στη γραμμή διευθύνσεων



Δοκιμή 1: Τροποποίηση του server.pem

Έγινε δοκιμή αλλοίωσης ενός byte στο αρχείο server.pem με nano:

Μετά την επανεκκίνηση του server, ο browser εμφάνισε: αποτυχία σύνδεσης και μη έγκυρο πιστοποιητικό.

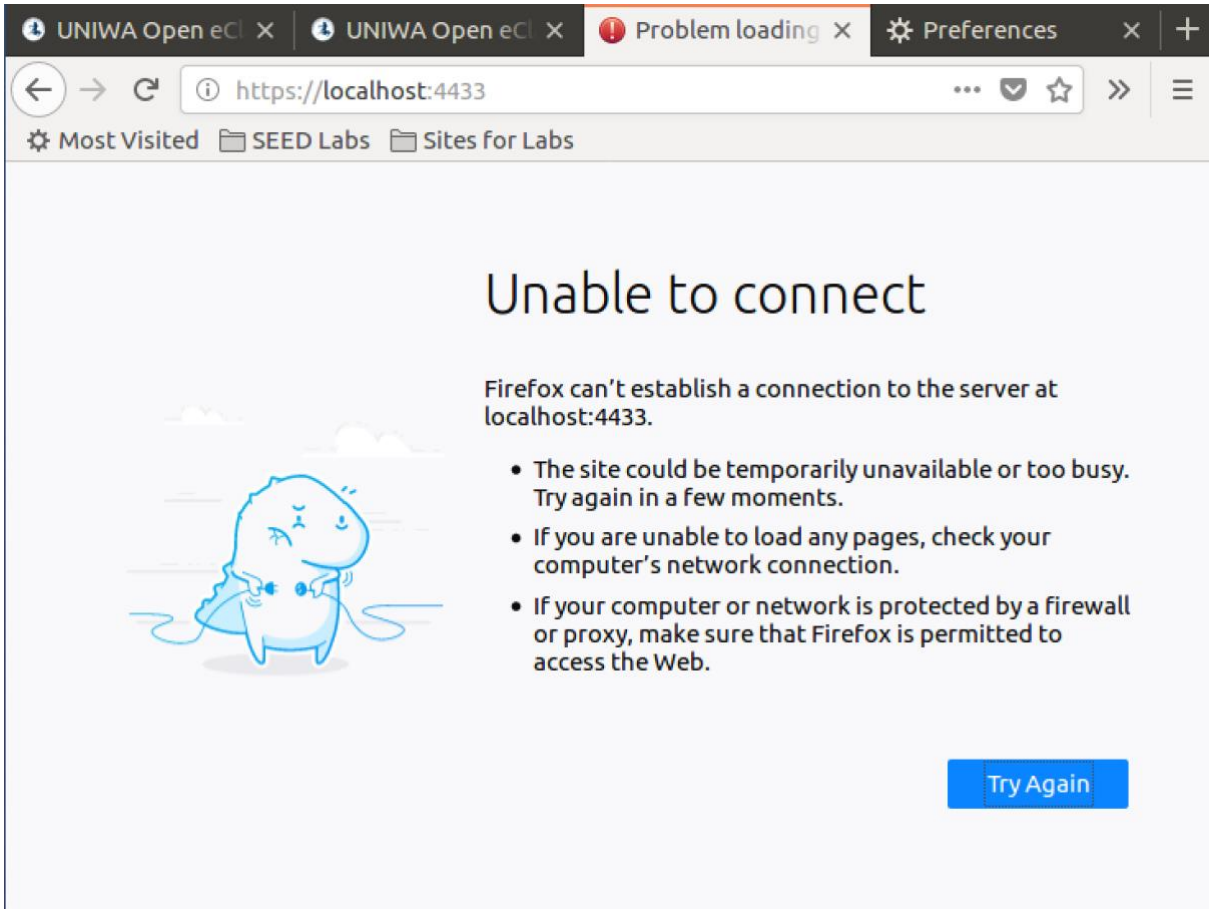


Δοκιμή 2: Εναλλακτικό hostname (localhost)

Η ίδια διεύθυνση δοκιμάστηκε με:

```
https://localhost:4433
```

Παρατηρήθηκε προειδοποίηση για **μη αντιστοιχία CN**, καθώς το CN του πιστοποιητικού είναι pantelis-karabetsos.gr και όχι localhost.



Συμπεράσματα

Η Δραστηριότητα 3 απέδειξε πώς ένα πιστοποιητικό που υπογράφηκε από την ΑΠ μπορεί να χρησιμοποιηθεί για ασφαλή επικοινωνία HTTPS. Επίσης, επιβεβαιώθηκε ο ρόλος της ΑΠ ως έμπιστου ενδιάμεσου και ο τρόπος με τον οποίο η χειροκίνητη εισαγωγή της στον browser ενεργοποιεί την αποδοχή του πιστοποιητικού του πελάτη.

♦ Δραστηριότητα 4: Χρήση του Πιστοποιητικού σε Apache HTTPS Web Server

Η παρούσα δραστηριότητα στοχεύει στη φιλοξενία του ιστότοπου του πελάτη (pantelis-karabetsos.gr) μέσω ενός πραγματικού web server με υποστήριξη HTTPS. Χρησιμοποιήθηκε ο Apache HTTP Server, ο οποίος είναι ήδη προεγκατεστημένος στο SEED Ubuntu.

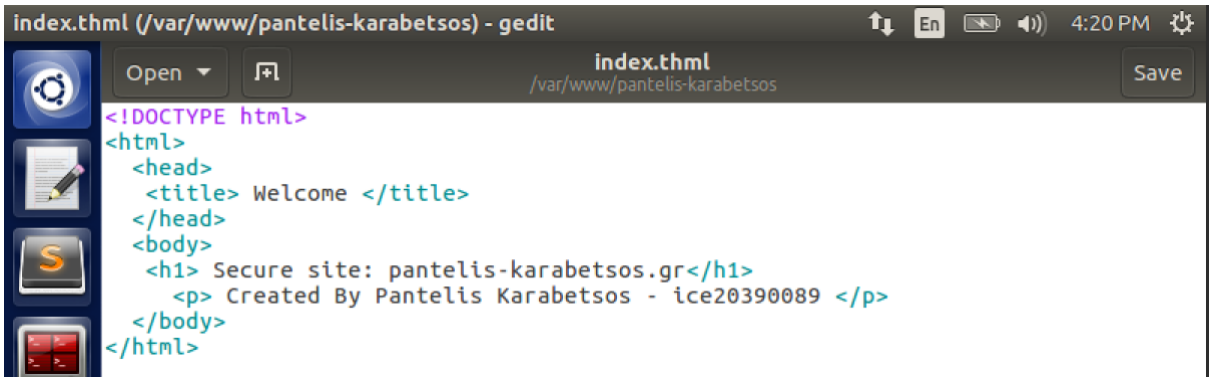
• Βήμα 1: Δημιουργία του ιστότοπου

Δημιουργήθηκε ο φάκελος του ιστότοπου:

```
sudo mkdir /var/www/pantelis-karabetsos
```

```
[06/02/25]seed@VM:~/.../pki$ sudo mkdir /var/www/pantelis-karabetsos
[06/02/25]seed@VM:~/.../pki$ sudo gedit /var/www/pantelis-karabetsos/index.thml
```

Το αρχείο index.html δημιουργήθηκε με το ακόλουθο απλό περιεχόμενο:

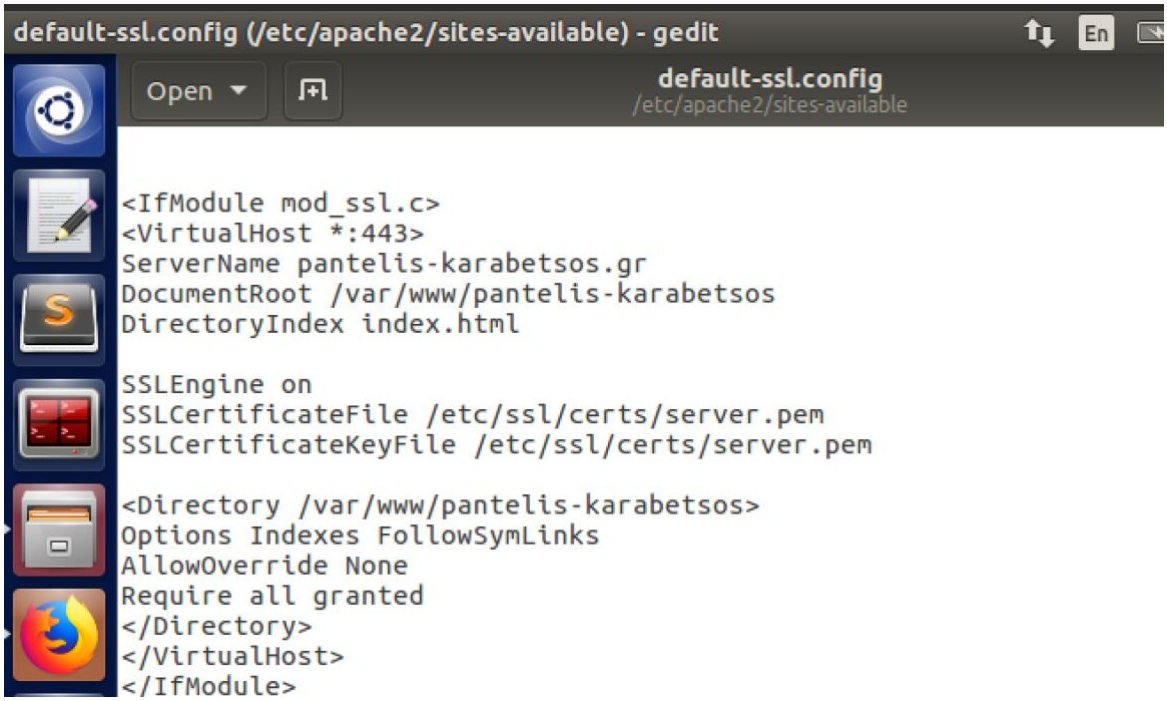


• Βήμα 2: Ρύθμιση του Apache

Επεξεργαστήκαμε το αρχείο `default-ssl.conf`:

```
sudo gedit /etc/apache2/sites-available/default-ssl.conf
```

Το αρχείο διαμορφώθηκε ως εξής:



- Βήμα 3: Ενεργοποίηση SSL και εκκίνηση Apache

Εκτελέστηκαν οι παρακάτω εντολές:

```
sudo apachectl configtest

sudo a2enmod ssl

sudo a2ensite default-ssl

sudo service apache2 restart
```

Κατά την επανεκκίνηση, ζητήθηκε το passphrase του `server.key`, καθώς είναι κρυπτογραφημένο.

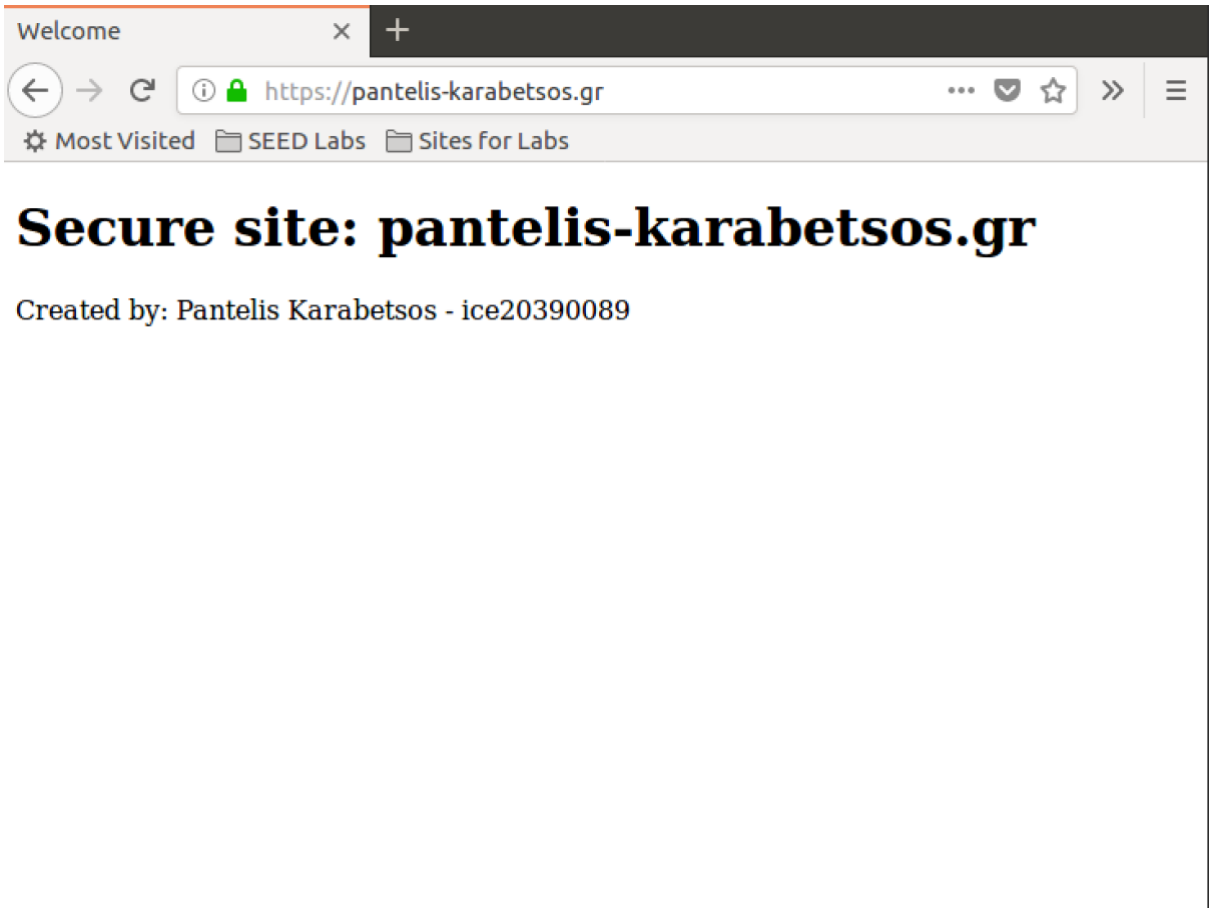
```
[06/03/25]seed@VM:~/.../pki$ sudo apachectl configtest
AH00112: Warning: DocumentRoot [/var/www/seedlabclickjacking] does not exist
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, u
sing 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
[06/03/25]seed@VM:~/.../pki$ sudo a2enmod ssl
Considering dependency setenvif for ssl:
Module setenvif already enabled
Considering dependency mime for ssl:
Module mime already enabled
Considering dependency socache_shmcb for ssl:
Module socache_shmcb already enabled
Module ssl already enabled
[06/03/25]seed@VM:~/.../pki$ sudo a2ensitive default-ssl
sudo: a2ensitive: command not found
[06/03/25]seed@VM:~/.../pki$ sudo a2ensite default-ssl
Site default-ssl already enabled
[06/03/25]seed@VM:~/.../pki$ sudo service apache2 restart
```

- Βήμα 4: Περιήγηση στον ιστότοπο

Ανοίξαμε το firefox και μεταβήκαμε στο:

```
https://pantelis-karabetsos.gr
```

Το πιστοποιητικό αναγνωρίστηκε ως έγκυρο, χάρη στην προηγούμενη εισαγωγή του `ca.crt` στον Firefox. Εμφανίστηκε το λουκέτο ασφαλείας, ενώ μέσω του Viewer επιβεβαιώθηκε ότι το πιστοποιητικό ανήκει στον πελάτη.



Συμπεράσματα

Η χρήση του πιστοποιητικού σε πραγματικό web server επιβεβαίωσε τη λειτουργικότητά του και την αξιοπιστία της ΑΠ. Η επικοινωνία με τον πελάτη πραγματοποιήθηκε μέσω HTTPS με πλήρη κρυπτογράφηση και ταυτοποίηση.

♦ Δραστηριότητα 5: Επίθεση τύπου Man-In-The-Middle (MITM)

Σκοπός της δραστηριότητας είναι να επιδειχθεί πώς η Υποδομή Δημοσίου Κλειδιού (ΥΔΚ) μπορεί να αποτρέψει επιθέσεις τύπου Man-In-The-Middle, όπου ένας εισβολέας παρεμβάλλεται στην επικοινωνία μεταξύ του χρήστη και ενός HTTPS ιστότοπου.

Σενάριο της επίθεσης

Ο εισβολέας επιδιώκει να παραπλανήσει τον χρήστη ώστε να πιστέψει ότι επισκέπτεται το νόμιμο site **https://seclab-2024.com**, ενώ στην πραγματικότητα οδηγείται στο κακόβουλο αντίγραφο **https://pantelis-karabetsos.gr** που φιλοξενείται στον τοπικό Apache server του επιτιθέμενου.

- ### Βήμα 1: Τροποποίηση του `default-ssl.conf`

Ο Apache server που φιλοξενεί το πλαστό site διαμορφώθηκε ώστε να απαντά σε αιτήματα προς `seclab-2024.com`:

```
<VirtualHost _default_:443>
…
    ServerName seclab-2024.com
    DocumentRoot /var/www/pantelis-karabetsos
    SSLEngine on
    SSLCertificateFile /etc/ssl/certs/server.pem
    SSLCertificateKeyFile /etc/ssl/certs/server.pem
…
</VirtualHost>
```

```
<IfModule mod_ssl.c>
    <VirtualHost _default_:443>
        ServerAdmin webmaster@localhost
        ServerName seclab-2024.com
        DocumentRoot /var/www/pantelis-karabetsos
        #DirectoryIndex index.html

        SSLEngine on
        SSLCertificateFile /etc/ssl/certs/server.pem
        SSLCertificateKeyFile /etc/ssl/certs/server.pem

        # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
        # error, crit, alert, emerg.
        # It is also possible to configure the loglevel for particular
        # modules, e.g.
        #LogLevel info ssl:warn

        ErrorLog ${APACHE_LOG_DIR}/error.log
        CustomLog ${APACHE_LOG_DIR}/access.log combined

        # For most configuration files from conf-available/, which are
        # enabled or disabled at a global level, it is possible to
        # include a line for only one particular virtual host. For example the
        # following line enables the CGI configuration for this host only
        # after it has been globally disabled with "a2disconf".
        #Include conf-available/serve-cgi-bin.conf

        #   SSL Engine Switch:
        #   Enable/Disable SSL for this virtual host.
```

- ## Βήμα 2: DNS spoofing μέσω /etc/hosts

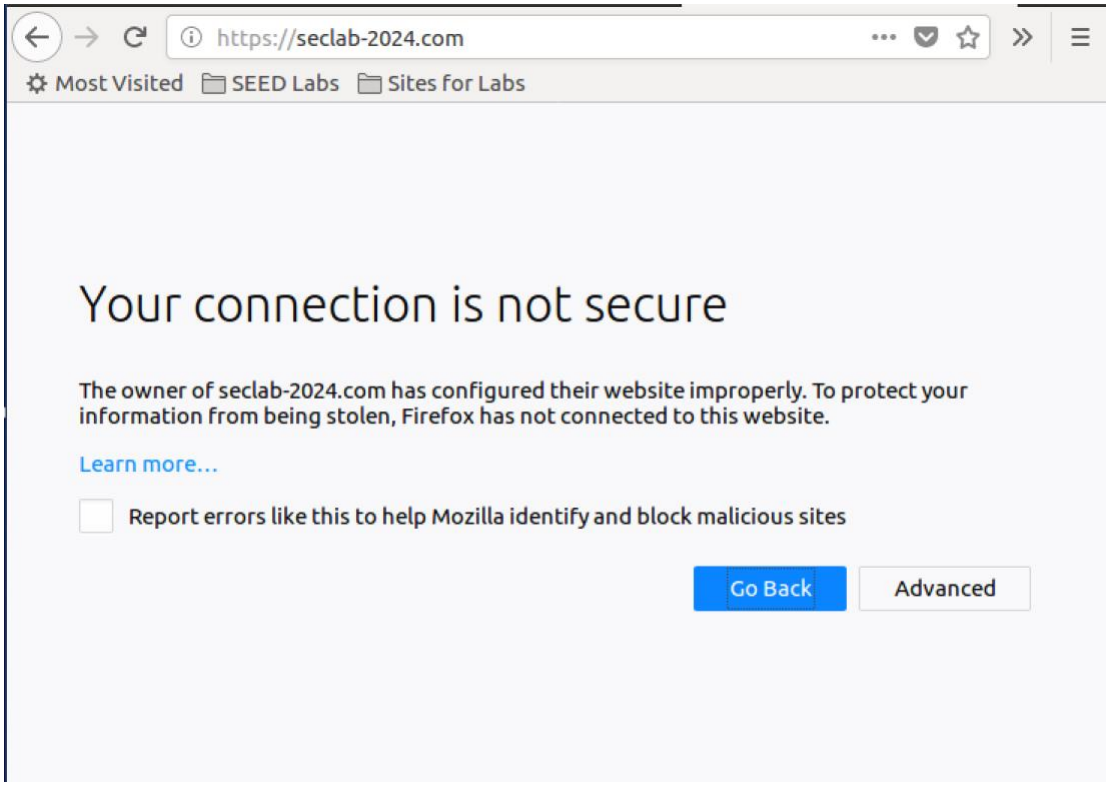
Το αρχείο `/etc/hosts` του "θύματος" τροποποιήθηκε ώστε να κατευθύνει το `seclab-2024.com` στον τοπικό υπολογιστή:

```
127.0.0.1 seclab-2024.com
```

Έτσι, οποιοδήποτε αίτημα προς `seclab-2024.com` οδηγείται στον Apache server του επιτιθέμενου.

- ## Βήμα 3: Απόπειρα πρόσβασης από τον browser

Μεταβήκαμε στη διεύθυνση https://seclab.com στο firefox



Ο browser εμφάνισε *προειδοποίηση ασφαλείας*, καθώς το πιστοποιητικό του κακόβουλου site δεν αντιστοιχεί στο *seclab-2024.com*. Αν και ο επιτιθέμενος παραπλανά τον DNS μηχανισμό, η ΥΔΚ προστατεύει τον χρήστη, εφόσον το πιστοποιητικό δεν αντιστοιχεί στο CN seclab-2024.com

Συμπεράσματα

Η απόπειρα MITM απέτυχε, καθώς η ΑΠ του επιτιθέμενου δεν είχε εκδώσει έγκυρο πιστοποιητικό για το `seclab-2024.com`. Ο browser εντόπισε τη αναντιστοιχία μεταξύ ορατής διεύθυνσης URL και Common Name του πιστοποιητικού, αποδεικνύοντας την αξία των ΥΔΚ στην προστασία του τελικού χρήστη από κακόβουλες παρεμβάσεις.

♦ Δραστηριότητα 6: Επίθεση τύπου Man-In-The-Middle σε Περίπτωση Παραβιασμένης Αρχής Πιστοποίησης (CA)

Η δραστηριότητα αυτή προσομοιώνει το σενάριο στο οποίο η Αρχή Πιστοποίησης (CA) έχει παραβιαστεί και το ιδιωτικό της κλειδί έχει υποκλαπεί από έναν εισβολέα. Με βάση αυτό το υποθετικό σενάριο, ο επιτιθέμενος μπορεί πλέον να δημιουργεί και να υπογράφει αυθαίρετα πιστοποιητικά, κάνοντάς τα να φαίνονται έγκυρα για οποιοδήποτε domain.

Σκοπός της Επίθεσης

Να αποδείξουμε ότι αν ένας επιτιθέμενος αποκτήσει πρόσβαση στο ιδιωτικό κλειδί μιας έμπιστης CA, μπορεί:

- Να δημιουργήσει ένα ψεύτικο HTTPS website (π.χ. bank.com)
- Να υπογράψει ένα πιστοποιητικό για αυτό το domain
- Ο browser να μην εμφανίσει καμία προειδοποίηση, αφού το πιστοποιητικό φαίνεται έγκυρο (υπογεγραμμένο από την "έμπιστη" CA)

• Βήμα 1: Δημιουργία πιστοποιητικού για πλαστό ιστότοπο

Χρησιμοποιήθηκε το **παραβιασμένο ιδιωτικό κλειδί** της ΑΠ (`ca.key`) για να υπογραφεί ένα νέο πιστοποιητικό για το domain `bank.com`.

Η διαδικασία περιλάμβανε:

1. Δημιουργία νέου ιδιωτικού κλειδιού για το "bank.com":

```
openssl genrsa -aes128 -out attacker.key
```

2. Δημιουργία Certificate με CN = bank.com:

```
openssl req -new -key attacker.key -out attacker.csr -config openssl.cnf
```

3. Υπογραφή με την CA:

```
openssl ca -in attacker.csr -out attacker.crt -cert
ca.crt -keyfile ca.key -config openssl.cnf
```

```
[06/02/25]seed@VM:~/.../pki$ openssl ca -in attacker.csr -out attacker.crt -cert ca.crt -k
eyfile ca.key -config openssl.cnf
Using configuration from openssl.cnf
Enter pass phrase for ca.key:
Check that the request matches the signature
Signature ok
Certificate Details:
        Serial Number: 2 (0x2)
        Validity
            Not Before: Jun  2 21:22:35 2025 GMT
            Not After : Jun  2 21:22:35 2026 GMT
        Subject:
            countryName               = US
            stateOrProvinceName       = NY
            localityName              = NYC
            organizationName          = BankCorp
            organizationalUnitName    = Security
            commonName                = bank.com
            emailAddress              = support@bank.com
        X509v3 extensions:
            X509v3 Basic Constraints:
                CA:FALSE
            Netscape Comment:
                OpenSSL Generated Certificate
            X509v3 Subject Key Identifier:
                4D:E9:15:F8:2F:FD:53:BE:3A:D4:34:44:2B:C4:B7:3F:65:5C:77:87
            X509v3 Authority Key Identifier:
                keyid:D5:00:72:28:50:16:3D:87:45:8F:DC:90:1B:E8:20:12:11:BF:DE:BB

Certificate is to be certified until Jun  2 21:22:35 2026 GMT (365 days)
Sign the certificate? [y/n]:y


1 out of 1 certificate requests certified, commit? [y/n]y
Write out database with 1 new entries
```

- Βήμα 2: Ρύθμιση του Apache για το `bank.com`

Το αρχείο `/etc/apache2/sites-available/default-ssl.conf` τροποποιήθηκε ώστε να περιλαμβάνει:

```
<IfModule mod_ssl.c>
    <VirtualHost _default_:443>
        ServerAdmin webmaster@localhost
        ServerName bank.com
        DocumentRoot /var/www/pantelis-karabetsos
        SSLEngine on
        SSLCertificateFile /etc/ssl/certs/attacker.pem
        SSLCertificateKeyFile /etc/ssl/certs/attacker.pem

        # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
        # error, crit, alert, emerg.
        # It is also possible to configure the loglevel for particular
        # modules, e.g.
        #LogLevel info ssl:warn

        ErrorLog ${APACHE_LOG_DIR}/error.log
```

- ## Βήμα 3: Προσομοίωση DNS Spoofing

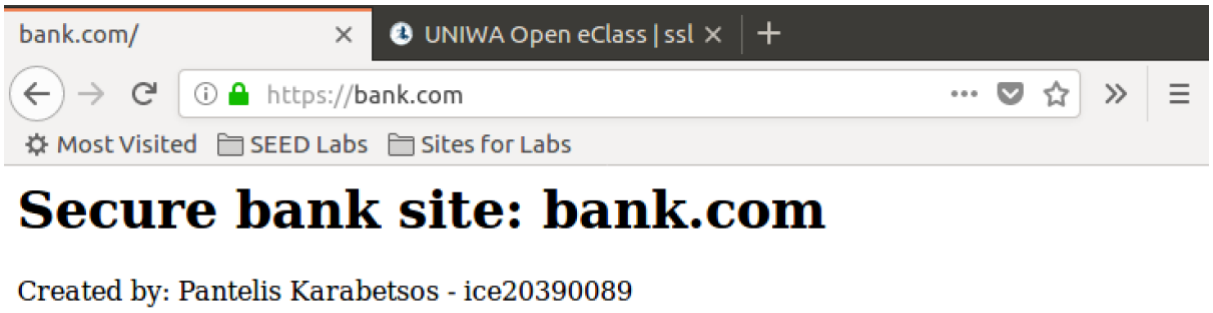
Στο `/etc/hosts` προστέθηκε:

```
127.0.0.1       bank.com
```

Έτσι, τα αιτήματα προς `bank.com` κατευθύνονταν τοπικά στον Apache server του επιτιθέμενου.

- ## Βήμα 4: Δοκιμή στο Browser

Μεταβήκαμε στο https://bank.com από το firefox



Εφόσον το πιστοποιητικό **έχει υπογραφεί από την CA που προηγουμένως είχε προστεθεί χειροκίνητα στον Firefox**, ο browser **δεν εμφάνισε προειδοποίηση**. Το πιστοποιητικό θεωρήθηκε έγκυρο.

Συμπεράσματα

Αυτή η προσομοίωση αναδεικνύει τον σημαντικό ρόλο της εμπιστοσύνης στις ΑΠ. Η παραβίαση μιας Αρχής Πιστοποίησης ισοδυναμεί με ολική κατάρρευση της ασφάλειας στο HTTPS: κάθε ιστότοπος μπορεί να πλαστογραφηθεί, κάθε πιστοποιητικό να "κατασκευαστεί" νόμιμα, και κανένας browser να μην μπορεί να το αντιληφθεί.

Το αποτέλεσμα επισημαίνει γιατί η προστασία των ιδιωτικών κλειδιών μιας ΑΠ είναι ζήτημα ύψιστης σημασίας και γιατί υπάρχουν διεθνή πρότυπα και μηχανισμοί για την ανάκληση ή τον αποκλεισμό τέτοιων πιστοποιητικών όταν συμβεί συμβιβασμός.

Σύνοψη

Στην παρούσα άσκηση εξερευνήσαμε στην πράξη τον τρόπο λειτουργίας των Υποδομών Δημοσίου Κλειδιού (PKI), μέσα από την υλοποίηση μιας πλήρους αλυσίδας εμπιστοσύνης: από τη δημιουργία μιας Αρχής Πιστοποίησης (CA), έως και τη χρήση ψηφιακών πιστοποιητικών σε πραγματικούς και ψεύτικους web servers.

Η άσκηση αναλύθηκε σε 6 δραστηριότητες, κάθε μία εκ των οποίων είχε ξεχωριστό εκπαιδευτικό στόχο:

- **Δραστηριότητα 1**: Υλοποιήθηκε μια *τοπική Αρχή Πιστοποίησης*, με σωστή διαμόρφωση αρχείων και δομών, βάσει του προτύπου X.509.
- **Δραστηριότητα 2**: Εκδόθηκε και υπογράφηκε από την ΑΠ το πιστοποιητικό ενος πελάτη (website)**,** ενσωματώνοντας πληροφορίες ταυτοποίησης.
- **Δραστηριότητα 3**: Ελέγχθηκε η χρήση του πιστοποιητικού σε έναν ενσωματωμένο OpenSSL HTTPS server**,** με έλεγχο εγκυρότητας μέσω browser.
- **Δραστηριότητα 4**: Το πιστοποιητικό χρησιμοποιήθηκε στον *Apache server*, με ασφαλή σύνδεση HTTPS και σωστή ρύθμιση του virtual host.
- **Δραστηριότητα 5**: Προσομοιώθηκε επίθεση *τύπου Man-In-The-Middle*, η οποία αποτράπηκε επιτυχώς λόγω της χρήσης έγκυρων πιστοποιητικών.
- **Δραστηριότητα 6**: Προσομοιώθηκε η περίπτωση *παραβιασμένης ΑΠ*, όπου παρουσιάστηκε πώς η ασφάλεια HTTPS καταρρέει όταν παραβιαστεί το ιδιωτικό κλειδί της Αρχής Πιστοποίησης.

Συμπεράσματα

Η δημιουργία και χρήση ψηφιακών πιστοποιητικών βασίζεται αποκλειστικά στην εμπιστοσύνη προς την ΑΠ**.** Ο έλεγχος του Common Name (CN) και η υπογραφή του πιστοποιητικού από έγκυρη CA είναι τα βασικά μέσα αποτροπής παραποίησης. Η ασφάλεια του ιδιωτικού κλειδιού της CA είναι κρίσιμη: οποιαδήποτε διαρροή καθιστά την ΥΔΚ αναξιόπιστη. Ο browser λειτουργεί ως **τελικός ελεγκτής εμπιστοσύνης**, απορρίπτοντας πιστοποιητικά που δεν μπορούν να επαληθευτούν σωστά.

Τι μάθαμε

Η άσκηση παρείχε ουσιαστική εμπειρία πάνω στη χρήση κρυπτογραφίας δημοσίου κλειδιού, τη διαχείριση πιστοποιητικών και τον εντοπισμό επιθέσεων μέσω HTTPS. Παράλληλα, ανέδειξε τη σημασία της εμπιστοσύνης στο πλαίσιο της ασφάλειας πληροφοριών και της ψηφιακής ταυτοποίησης.